



ISP-002 — Access Control and Identity Management Policy

Overleaf Publishers Ltd · Co. No. 15735226 · VAT No. 479581629 · Version 1.0 · July 2026 · chainsawcourses.com

1. PURPOSE AND SCOPE

This policy defines the principles, requirements, and controls governing access to Overleaf Publishers Ltd's information systems, data, and physical assets. It applies to all personnel, contractors, and third-party providers who have access to any organisational system or data, whether on-site or remote. Document reference: ISP-002.

The objective is to ensure that access to information assets is granted on a least-privilege, need-to-know basis; is formally authorised before it is granted; is monitored during use; and is promptly revoked when no longer required.

2. ACCESS CONTROL PRINCIPLES

- Least privilege: users are granted the minimum level of access required to perform their authorised function — no more.
- Need-to-know: access to sensitive data (learner records, financial data, admin functions) is restricted to personnel with a documented business need.
 - Separation of duties: where feasible, no single individual controls all steps of a sensitive process.
 - Formal authorisation: all access grants are explicitly authorised by the Director before provisioning.
 - Regular review: access rights are reviewed at minimum annually and upon any change in role.
 - Prompt revocation: access is revoked within 24 hours of termination of employment or contractor engagement.

3. USER ACCESS MANAGEMENT

STAGE	CONTROL
Registration	New users registered only on written authorisation from the Director. System accounts created with minimum required permissions.
Provisioning	Access provisioned to specific systems/data only. Credentials issued via secure channel; never via email in plaintext.
Authentication	Strong authentication required: passwords minimum 12 characters, mixed case/number/symbol; MFA enforced for admin and cloud service access.
Periodic review	Access rights reviewed annually; dormant accounts (>90 days inactive) suspended and reviewed.
Termination	All access revoked within 24 hours of departure. Shared credentials changed immediately. Equipment and physical access items recovered.

4. PLATFORM ACCESS TIERS



TIER — USERS — AUTHENTICATION	ACCESS RIGHTS
Learner — Registered students — Activation code + device UUID bond	Own progress, quiz results, waiver, inspection, and risk assessment records only
Administrator — Director only — Admin password + in-memory token (24h TTL)	All learner records; content management; activation code management; waiver PDFs; device bond reset
Infrastructure — Director / authorised contractors — Replit account + MFA	Replit workspace, database, server code, environment secrets; access via Replit RBAC

5. PRIVILEGED ACCESS MANAGEMENT

- Administrative access to the platform backend and database is restricted to the Director and explicitly authorised contractors.
- Admin tokens have a 24-hour TTL and are stored in-memory only — they do not persist across server restarts.
- Database access is not exposed to the public internet; all access is via application API or authorised Replit console.
- Environment secrets (API keys, DATABASE_URL, SESSION_SECRET) are stored exclusively in Replit Secrets and are never logged or displayed.
- Any access required for maintenance or debugging by a third party is granted on a time-limited, task-specific basis and revoked immediately on completion.

6. REMOTE ACCESS

All remote access to organisational systems and data is: conducted over encrypted connections (HTTPS/TLS); from devices with full-disk encryption enabled and up-to-date security patching; and subject to the same authentication requirements as on-premises access. Use of public Wi-Fi for accessing sensitive data without a VPN is prohibited.

7. PASSWORD POLICY

- Minimum length: 12 characters.
- Complexity: must include uppercase, lowercase, numbers, and special characters.
- Password reuse: last 10 passwords may not be reused.
- Password sharing: strictly prohibited — each user must have a unique credential.
- Compromise response: passwords changed immediately on suspicion of compromise; all active sessions invalidated.
- Password managers: recommended for all personnel to generate and store strong, unique passwords.

8. MULTI-FACTOR AUTHENTICATION

MFA is mandatory for: all cloud infrastructure accounts (Replit, Vimeo, payment platforms, email); admin access to platform backend; and access to any system holding personal data or financial information. Acceptable MFA methods: authenticator app (TOTP); hardware security key (FIDO2). SMS-based MFA is acceptable where other methods are not supported by the service.

9. ACCESS REVIEW AND REVOCATION

A formal access review is conducted at least annually. The review confirms: all active access accounts have a current business justification; permissions match current roles; dormant accounts are suspended; and no

orphaned accounts from previous contractor engagements remain active. Findings are recorded in the Access Review Register and any anomalies are raised as nonconformances.

10. POLICY REVIEW

This policy is reviewed annually and following any security incident, significant personnel change, or material change to the system architecture. Controlled under reference ISP-002.

For queries: info@chainsawcourses.com · Overleaf Publishers Ltd · Reg. No. 15735226 · VAT 479581629